BUSINESS CONTINUITY AND DISASTER RECOVERY

GRC205 - INCIDENT MANAGEMENT AND BUSINESS CONTINUITY

WEEK 21 | DECEMBER 8-14

INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

Building Organizational Resilience Through BC/DR Planning

WEEK 21 CONTEXT

This week transitions from reactive incident response to proactive business continuity and disaster recovery planning. While incident response addresses security events after they occur, BC/DR ensures organizations can maintain critical operations during any disruption and recover quickly when systems fail.

The distinction is crucial: incident response focuses on cybersecurity threats, while BC/DR addresses all potential disruptions including natural disasters, technology failures, supply chain interruptions, and human errors.

LEARNING OBJECTIVES

Understand the relationship between business continuity, disaster recovery, and incident response within the broader GRC framework

Master the Business Impact Analysis (BIA) methodology to identify critical business functions and establish recovery priorities

Define and apply Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO) to guide recovery strategy selection

Develop comprehensive BC/DR plans aligned with NIST SP 800-34 and ISO 22301 standards

Implement effective testing and exercise programs to validate BC/DR capabilities

KEY FRAMEWORKS

NIST SP 800-34

ISO 22301

FEMA CONTINUITY PLANNING

Business Continuity and Disaster Recovery Serve Complementary But Distinct Purposes

BUSINESS CONTINUITY

SCOPE & FOCUS

Ensures the entire organization can continue delivering products and services during and after a disruption. Extends beyond IT to encompass all business functions including operations, supply chain, human resources, facilities, and communications.

TIMING

Maintains functional level of operations before, during, and after an event through proactive planning and continuous execution throughout the incident lifecycle.

PRIMARY GOAL

Sustaining mission-critical business processes to minimize operational and financial impact across the entire organization.

DISASTER RECOVERY

SCOPE & FOCUS

Focuses specifically on recovering IT systems, data, and infrastructure after a disaster has occurred. Limited to technology components including servers, networks, applications, databases, and data centers.

TIMING

Outlines the process to respond to an event when it occurs and restore normal operations. Timing begins after disruption has occurred and focuses on recovery execution.

PRIMARY GOAL

Restoring IT systems and infrastructure to enable business operations to resume with minimal data loss and downtime.

KEY RELATIONSHIP

Disaster recovery is a critical subset of business continuity. Effective business continuity cannot exist without robust disaster recovery capabilities, but disaster recovery alone is insufficient for comprehensive organizational resilience. Modern BC/DR programs integrate both disciplines into a unified framework addressingall potential disruptions.

NIST Provides Seven-Step Methodology for Information System Contingency Planning

NIST Special Publication 800-34 Revision 1 establishes the authoritative framework for contingency planning in federal information systems, widely adopted across public and private sectors. The framework encompasses the entire lifecycle from policy development through ongoing maintenance.

STEP 1 **Develop Contingency Planning Policy Statement**

Establish formal policy defining contingency objectives, roles, resources, training, testing schedules, and maintenance requirements.

STEP 2 **Conduct Business Impact Analysis (BIA)**

Identify critical IT systems by correlating them to mission/business processes and determine impact of disruptions to establish recovery priorities.

STEP 3 **Identify Preventive Controls**

Implement cost-effective controls to reduce likelihood and impact of disruptions including redundant systems, UPS, backup generators, and security controls.

STEP 4 **Create Contingency Strategies**

Develop strategies to recover IT systems based on BIA findings, balancing cost against recovery speed through alternate sites, backup methods, and recovery approaches.

STEP 5 **Develop Information System Contingency Plan (ISCP)**

Document detailed procedures for recovering information systems including activation, notification, recovery, reconstitution procedures, and supporting appendices.

STEP 6 **Ensure Plan Testing, Training, and Exercises (TT&E)**

Test plans regularly to identify gaps, validate procedures, and ensure personnel know their roles. Testing progresses from tabletop to full-scale exercises.

STEP 7 **Plan Maintenance**

Review and update plans at least annually to remain current with organizational changes, technology

Business Impact Analysis Identifies Critical Functions and Establishes Recovery Priorities

The Business Impact Analysis (BIA) is the cornerstone of effective BC/DR planning, providing the data-driven foundation for all recovery strategies and resource allocation decisions. A BIA predicts the consequences of disruptions to business operations and gathers information needed to develop recovery strategies.

PHASE 1: IDENTIFY CRITICAL FUNCTIONS

Document all business processes, categorize by criticality, map to supporting IT systems, and identify dependencies between functions.

PHASE 2: DETERMINE IMPACTS

Quantify operational impacts (lost sales, increased expenses, regulatory fines) and financial impacts (revenue loss, legal costs, long-term implications).

PHASE 3: ESTABLISH RTO

Define maximum acceptable downtime for each function considering timing, duration, seasonal patterns, and cumulative effects over time.

PHASE 4: ESTABLISH RPO

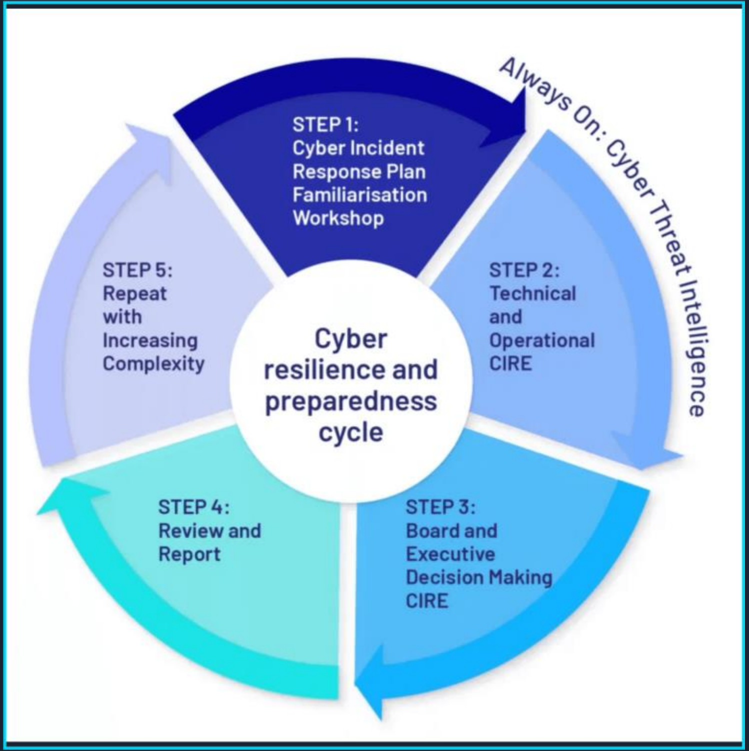
Define maximum acceptable data loss measured in time, driving backup frequency requirements and data protection strategies.

PHASE 5: IDENTIFY RESOURCES

Document personnel, technology, facilities, third-party services, and critical documentation needed to recover each function.

PHASE 6: PRIORITIZE RECOVERY

Rank business functions by criticality, establish recovery sequence, identify critical path activities, and balance needs with constraints.



TIMING CONSIDERATIONS

The point in time when disruption occurs significantly affects impact severity. Organizations must consider seasonal variations, business cycles, duration thresholds, and cumulative effects over time.

Recovery Objectives Define Acceptable Downtime and Data Loss Thresholds

RTO

Recovery Time Objective

Maximum acceptable downtime from disruption to full restoration; drives recovery speed and strategy.

RPO

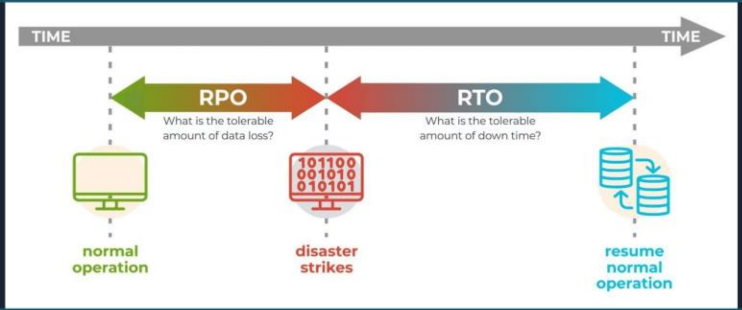
Recovery Point Objective

Maximum acceptable data loss in time; defines the recovery point and backup frequency.

MTD

Maximum Tolerable Downtime

Absolute maximum outage before irreparable harm; includes RTO plus recovery and validation time.



PRACTICAL EXAMPLES

E-COMMERCE PLATFORM

RTO: 1 hour | RPO: 15 min | MTD: 4 hours | Strategy: Hot site with real-time replication

EMAIL SYSTEM

RTO: 4 hours | RPO: 1 hour | MTD: 24 hours | Strategy: Warm site with hourly backups

DOCUMENT ARCHIVE

RTO: 5 days | RPO: 24 hours | MTD: 30 days | Strategy: Cold site with daily cloud backups

Cost-Benefit Balance

Aggressive RTO/RPO can cost 10x+; balance needs vs budget with tiered objectives: T1 mission-critical, T2 important, T3 non-critical.

Alternate Site Selection Balances Recovery Speed Against Cost

HOT SITE

RTO

Minutes to 1-2 hours

RPO

Near zero

COST

Highest

BEST FOR

Mission-critical systems requiring 99.99%+ uptime. Financial trading, emergency services, e-commerce platforms.

WARM SITE

RTO

Hours to 1-2 days

RPO

Hours to 1 day

COST

Moderate

BEST FOR

Important systems with moderate downtime tolerance. ERP systems, CRM platforms, corporate email.

COLD SITE

RTO

Days to weeks

RPO

Days

COST

Lowest

BEST FOR

Non-critical systems with high downtime tolerance. Development environments, archival systems, administrative apps.

MOBILE SITE

RTO

1-3 days + transport

RPO

Varies

COST

Moderate

BEST FOR

Organizations with multiple locations or unpredictable disaster scenarios. Portable recovery facility.

MIRRORED (ACTIVE-ACTIVE)

RTO

Near zero

RPO

Zero

COST

Highest

BEST FOR

Critical infrastructure requiring continuous availability. Healthcare systems, core banking, telecommunications.

CLOUD-BASED DISASTER RECOVERY (DRaaS)

Cloud platforms provide scalable recovery without physical sites. Flexible RTO/RPO based on configuration, pay-as-you-go pricing, geographic distribution across regions. Eliminates physical site management while offering warm or hot recovery capabilities.

SITE SELECTION CRITERIA

Evaluate based on: geographic distance from primary site (outside disaster zone), connectivity and bandwidth (sufficient for replication), environmental controls and security, cost and contract terms, testing and access policies.

Effective Backup Strategies Ensure Data Availability for Recovery

FULL BACKUP

BACKUP TIME
Longest (hours for large datasets)

RESTORE TIME
Fastest (single operation)

STORAGE
Highest (complete copy)

FREQUENCY
Weekly or monthly

INCREMENTAL

BACKUP TIME
Fastest (minimal data)

RESTORE TIME
Slower (full + all incrementals)

STORAGE
Lowest (only changes)

FREQUENCY
Daily or multiple times per day

DIFFERENTIAL

BACKUP TIME
Moderate (increases over time)

RESTORE TIME
Moderate (full + last differential)

STORAGE
Moderate (cumulative changes)

FREQUENCY
Daily between full backups

CDP

BACKUP TIME
Continuous (real-time)

RESTORE TIME
Any point in time

STORAGE
Highest (all changes)

FREQUENCY
Real-time continuous protection

3

Maintain at least THREE copies of data

(Production + 2 backups)

2

Store backups on TWO different media types

(Disk and tape, or disk and cloud)

1

Keep ONE backup copy offsite

(Protected from site-specific disasters)

INDUSTRY BEST PRACTICE: THE 3-2-1 BACKUP RULE

Protects against hardware failure, media-specific failures, and site disasters through redundancy and geographic distribution

BACKUP TESTING

Regular testing validates data integrity, restore procedures, and recovery time. Test quarterly for critical systems, annually for all systems.

CLOUD BACKUP

Offers geographic redundancy, scalability, automation, and cost efficiency. Consider bandwidth, compliance, encryption, and vendor lock-in.

ISO 22301 Provides International Framework for Systematic BC Management

ISO 22301:2019 is the international standard for Business Continuity Management Systems (BCMS), providing a structured framework for organizations to plan, establish, implement, operate, monitor, review, maintain, and continually improve their business continuity capabilities.

ISO 22301 STRUCTURE (10 CLAUSES)

CLAUSE 1-3	Scope, references, definitions
CLAUSE 4	Context of organization
CLAUSE 5	Leadership and commitment
CLAUSE 6	Planning and risk management
CLAUSE 7	Support and resources
CLAUSE 8	**Operation (BIA, strategies, plans)**
CLAUSE 9	Performance evaluation
CLAUSE 10	Improvement and corrective action

IMPLEMENTATION APPROACH

Gap analysis → Planning → BIA and risk assessment → Strategy development → Plan development → Testing and exercises → Certification audit → Continuous improvement

BCMS VS TRADITIONAL BC/DR

- Holistic, organization-wide scope (not just IT systems)
- Integrated with overall risk management and business strategy
- Continuous improvement cycle (Plan-Do-Check-Act methodology)
- Addresses all types of disruptions beyond technology failures
- Focus on maintaining critical business functions across entire organization

BENEFITS OF CERTIFICATION

- Demonstrated commitment to resilience (third-party validated)
- Competitive advantage and market differentiation
- Improved stakeholder confidence (customers, regulators, investors)
- Regulatory compliance (meets many industry requirements)
- Enhanced organizational resilience through systematic approach

KEY CLAUSE 8: OPERATION

Core BC activities including Business Impact Analysis, risk assessment, BC strategies and solutions, and BC plans and procedures. Transforms planning into operational capability.

Comprehensive BC/DR Plans Provide Clear Guidance During Disruptions

EXECUTIVE SUMMARY & PURPOSE

Plan purpose, scope, and applicability. Defines what the plan covers, which business functions or systems it addresses, and when it should be activated. Enables quick understanding for executives and stakeholders.

ROLES & RESPONSIBILITIES

BC/DR team structure, specific roles (incident commander, communications lead, technical recovery lead), decision-making authority and escalation paths, contact information for all team members including alternates.

ACTIVATION & NOTIFICATION

Activation criteria and decision authority, notification procedures for team members and stakeholders, communication methods (primary and backup channels), initial assessment and situation reporting procedures.

RECOVERY PROCEDURES

Detailed step-by-step recovery procedures organized by system or business function. Include prerequisites and dependencies, expected outcomes and validation criteria, estimated time requirements, and rollback procedures if recovery fails.

COMMUNICATION PLANS

Internal and external communication during disruptions. Stakeholder identification and requirements, communication templates for common scenarios, approval workflows for external communications, media management and regulatory notification requirements.

RESOURCE REQUIREMENTS

Personnel (skills, numbers, availability), technology (hardware, software, licenses, credentials), facilities (alternate sites, workspace, utilities), vendors and service providers (contact information, contracts, SLAs), supplies and equipment.

TESTING & MAINTENANCE

Testing schedule and methodologies, maintenance procedures and update frequency, version control and change management, distribution and access procedures, training requirements for plan users.

APPENDICES & SUPPORTING INFO

System inventories and configurations, network diagrams and architecture documentation, vendor contact information and contracts, regulatory requirements and compliance obligations, forms and templates, glossary of terms.

Regular Testing Validates Plans and Builds Team Capability

TABLETOP EXERCISE

LOW RISK

Discussion-based session where team members talk through responses to scenario. No actual system changes. **Frequency:** Quarterly. **Best for:** Plan review, team coordination, identifying gaps.

WALKTHROUGH TEST

LOW-MODERATE

Step-by-step review of plan procedures with team members simulating actions verbally. May review documentation and verify resources. **Frequency:** Semi-annually. **Best for:** Procedure validation, role clarification.

SIMULATION EXERCISE

MODERATE

Realistic scenario with time pressure requiring team to respond as if real incident. Some system testing in isolated environments. **Frequency:** Annually. **Best for:** Decision-making practice, stress testing procedures.

PARALLEL TEST

MODERATE-HIGH

Recovery systems activated alongside production systems. Validates recovery capability without risking production. **Frequency:** Annually. **Best for:** Technology validation, performance testing.

FULL INTERRUPTION TEST

HIGH RISK

Production systems actually shut down with complete failover to recovery systems. Rarely performed due to business impact. **Frequency:** Every 2-3 years (if at all). **Best for:** Complete validation, regulatory compliance.

TESTING BEST PRACTICES

Test Many Scenarios: Vary failure types, times, and scopes. Don't test same scenario repeatedly.

Test Regularly: Establish schedule and adhere to it. Test after significant environment changes.

Document Everything: Record procedures, results, issues, corrective actions, and performance metrics.

Keep Everyone Updated: Communicate schedule in advance, provide status updates, share results with stakeholders.

Measure Performance: Track actual vs. target RTO/RPO, test success rate, issues identified, resolution time.

Learn and Improve: Update plans based on findings, remediate issues, enhance procedures, track improvement trends.

KEY TESTING METRICS

Coverage: % of critical systems tested, % of procedures tested

Performance: Actual vs. target RTO/RPO, test success rate

Compliance: Tests completed vs. scheduled, audit findings

COMMON CHALLENGES

Business Resistance: Demonstrate value, minimize disruption. **Resource Constraints:** Prioritize critical systems, leverage tabletops. **Complex Dependencies:** Map dependencies, test incrementally.

Effective BC/DR Requires Clear Governance and Defined Roles

BC/DR GOVERNANCE STRUCTURE

EXECUTIVE STEERING COMMITTEE

Senior leadership provides strategic direction, approves BC/DR strategies and budgets, ensures alignment with business objectives, reviews program performance. Includes CEO, CFO, CIO/CISO, COO, General Counsel. Meets quarterly.

BC/DR PROGRAM MANAGER

Day-to-day leadership and coordination, develops and maintains BC/DR program, coordinates BIA and risk assessment, oversees plan development and maintenance, manages testing and exercise program, reports to steering committee.

BUSINESS CONTINUITY COORDINATORS

Each business unit designates BC coordinator responsible for unit-specific BC planning, conducting BIA for their area, developing and maintaining unit BC plans, coordinating testing, serving as liaison to program manager.

DISASTER RECOVERY TEAM

DR Team Lead coordinates all DR activities. System administrators restore specific systems. Network engineers restore connectivity. Database administrators restore and validate databases. Application specialists restore and test applications. Security specialists ensure security during recovery.

CRISIS MANAGEMENT TEAM

Handles overall incident management and strategic decisions. Incident Commander (overall authority), Communications Lead (internal/external), Legal Counsel (regulatory/legal), HR Representative (personnel/safety), Facilities Manager (physical site/logistics).

RACI MATRIX FOR BC/DR

ACTIVITY	R	A	C	I
Plan Development	BC Coord	Prog Mgr	BU	Exec
BIA Conduct	Prog Mgr	BU Lead	Process	Exec
Testing Execution	DR Team	Prog Mgr	BU	Exec
Plan Activation	Inc Cmd	Exec Spon	Prog Mgr	All Staff

R =Responsible | **A** =Accountable | **C** =Consulted | **I** =Informed

GOVERNANCE PROCESSES

PROGRAM PLANNING & BUDGETING

Annual planning establishes objectives, priorities, resources. Program manager develops plan, steering committee approves, budget allocated, progress tracked.

RISK & PERFORMANCE MONITORING

Ongoing monitoring through KPIs, risk assessments, audit findings, incident and test results analysis ensures program effectiveness.

CONTINUOUS IMPROVEMENT

Lessons learned from tests and incidents, benchmarking, maturity assessments, program enhancements drive continuous improvement.

COMMUNICATION & REPORTING

Quarterly steering committee meetings, monthly program status reports, annual board review, ad-hoc updates for significant events.

Metrics Drive BC/DR Program Maturity and Effectiveness

KEY PERFORMANCE INDICATORS

AVAILABILITY & RELIABILITY

System uptime % (99.9%, 99.99%, 99.999%) • Mean time between failures (MTBF) • Mean time to repair (MTTR)

RECOVERY PERFORMANCE

Actual RTO vs. target RTO • Actual RPO vs. target RPO • Recovery success rate • Data loss incidents

TESTING & EXERCISES

Number of tests per year • Test success rate • Issues identified during testing • Time to resolve findings

COMPLIANCE & GOVERNANCE

Plan update frequency • Training completion rate • Audit findings • Regulatory compliance status

FINANCIAL METRICS

BC/DR costs as % of IT budget • Cost per protected system • Cost of downtime avoided • ROI of investments

CONTINUOUS IMPROVEMENT PROCESS

Quarterly program reviews • Annual maturity assessment • Lessons learned integration • Benchmarking against industry peers

BC/DR MATURITY ASSESSMENT MODEL

LEVEL 1: INITIAL (AD HOC)

BC/DR activities reactive and informal. No formal plans. Recovery relies on individual heroics. Success unpredictable. High risk.

LEVEL 2: DEVELOPING (REPEATABLE)

Basic BC/DR plans exist for critical systems. Some testing but not regular. Roles defined but not always followed. Variable success.

LEVEL 3: DEFINED (STANDARDIZED)

Comprehensive BC/DR program with documented processes. Regular testing across critical systems. Clear governance. Consistent recovery success.

LEVEL 4: MANAGED (MEASURED)

BC/DR driven by metrics and data. Proactive gap identification and remediation. Integration with enterprise risk management. Continuous improvement.

LEVEL 5: OPTIMIZING (CONTINUOUS IMPROVEMENT)

BC/DR is core organizational competency. Innovation in recovery approaches. Industry leadership and best practices. Resilience embedded in culture.

MATURITY ADVANCEMENT

Organizations should assess current maturity level, identify gaps to next level, develop roadmap for advancement, and track progress through metrics and benchmarking.

Incident Response and BC/DR Form Complementary Resilience Framework

INCIDENT RESPONSE SCOPE

Focus: Cybersecurity Incidents

Addresses malware infections, unauthorized access, data breaches, denial of service attacks, and insider threats. Primary goal: minimize security impact and restore secure operations through detection, analysis, containment, eradication, and recovery.

BC/DR SCOPE

Focus: All Disruptions

Addresses natural disasters, technology failures, supply chain interruptions, facility access issues, and cybersecurity incidents. Primary goal: minimize business impact and restore normal operations while maintaining critical business functions.

INTEGRATION POINTS

SHARED ACTIVATION

Major cybersecurity incidents trigger both IR and BC/DR. Ransomware requires IR (threat containment) and DR (system recovery). DDoS requires IR (attack mitigation) and BC (alternate service delivery).

COORDINATED TEAMS

Unified command structure with clear decision authority, shared communication and coordination procedures, joint exercises and training, and maintained shared situation awareness.

UNIFIED GOVERNANCE

Common governance ensuring alignment, shared resources and budget, consistent policies and standards, and integrated risk management across both disciplines.

CASE EXAMPLE: RANSOMWARE ATTACK COORDINATED RESPONSE

HOUR 0-4: DETECTION & INITIAL RESPONSE

IR Team: Detects ransomware, initiates incident response, contains affected systems, preserves evidence.

BC/DR Team: Assesses business impact, activates business continuity procedures, communicates with stakeholders.

HOUR 4-24: CONTAINMENT & INVESTIGATION

IR Team: Investigates attack vector, identifies scope of compromise, eradicates attacker access.

BC/DR Team: Activates alternate processing, maintains critical operations, coordinates customer communication.

HOUR 24-72: RECOVERY & RESTORATION

IR Team: Validates environment is clean and secure, monitors for re-infection.

BC/DR Team: Restores systems from clean backups, validates data integrity, returns to normal operations.

Post-Incident: Joint IR and BC/DR lessons learned session identifies improvements to both capabilities, updates plans and procedures, implements preventive measures.

BC/DR Enables Organizations to Survive and Thrive Through Disruptions

CORE PRINCIPLES OF EFFECTIVE BC/DR

BUSINESS-DRIVEN

BC/DR aligns with business objectives and priorities. BIA identifies critical processes. Recovery strategies balance needs and cost.

RISK-BASED

Prioritize high-impact scenarios. Not all systems need the same protection. Use tiers based on criticality and risk.

TESTED & VALIDATED

Plans must be tested regularly. Exercises reveal gaps and build capability, from tabletop to full-scale.

CONTINUOUSLY IMPROVED

Learn from tests, incidents, and change. Update plans routinely. Advance maturity through metrics and benchmarking.

INTEGRATED

Integrate BC/DR with incident response, risk management, and architecture. Unified governance maximizes effectiveness.

PEOPLE-FOCUSED

Technology enables recovery, people execute it. Define roles, train teams, and foster a resilience culture.

KEY SUCCESS FACTORS

- ✓ **Executive Sponsorship:** Visible leadership support and adequate funding
- ✓
- ✓ **Appropriate Strategies:** Recovery approaches matched to RTO/RPO requirements
- ✓ **Clear Documentation:** Accessible, actionable plans with step-by-step procedures
- ✓ **Regular Testing:** Frequent validation builds confidence and identifies gaps
- ✓ **Skilled Team:** Trained personnel who know their roles and responsibilities
- ✓ **Metrics & Accountability:** KPIs drive performance and continuous improvement

COMMON PITFALLS TO AVOID

- ✗ **IT-Only Focus:** BC/DR is business program, not just IT backup
- ✗ **Stale Plans:** Outdated documentation is worse than no documentation
- ✗ **Insufficient Testing:** Annual testing is minimum; critical systems need more
- ✗ **Unrealistic RTOs:** Recovery objectives must be achievable and tested
- ✗ **Single Points of Failure:** Dependencies and key personnel create vulnerabilities
- ✗ **Compliance-Only Mindset:** Checkbox approach misses resilience goal
- ✗ **Ignoring Dependencies:** Third-party and supply chain risks often overlooked